

Psy-ARP: Automating MITM Attacks

Executive Summary:

Psy-ARP is a command-line tool that automates local Man-In-The-Middle (MITM) attacks through ARP spoofing, which positions the attacker as the man-in-the-middle between two hosts on a local, controlled network, and allows that attacker to view unencrypted network traffic, such as HTTP requests. The attacker could then redirect certain file requests, or otherwise view information that would normally be kept confidential. While it is meant for low-security environments, Psy-ARP could be upgraded to include SSL stripping, allowing attackers to potentially spy on HTTP requests. This write-up demonstrates the practical applications of this tool, highlights artefacts that would give away use of this tool and offers advice to protect networks from it.

Disclaimer:

The purpose of this tool is to demonstrate the exploitation process and give ethical hackers some useful assistance. It is to be used strictly for educational purposes and if applicable, for assistance during **legal** penetration tests, where scope allows. It is **not** intended to aid or empower cybercriminals, nor is it intended for black hat hacking. The creator does not authorize, condone, or take responsibility for any illegal actions performed with the provided source code.

General information:

Psy-ARP was built with Python, utilizing the `scapy` and `netfilterqueue` libraries to perform ARP spoofing, allowing the attacker's computer to intercept two hosts' network traffic. If the two hosts are communicating with each other via unencrypted protocols like HTTP, the attacker will be able to inspect network traffic and even redirect file requests. Once the script is intercepting the hosts' traffic, it can perform file redirections.

The tool was tested in a VirtualBox NAT Network, with a Kali Linux virtual machine serving as the attacker. The two hosts were an Ubuntu Linux virtual machine running an Apache webserver from Lampp, and a Linux Mint virtual machine, which represents an ordinary user. To successfully and accurately recreate the testing environment for your own purposes, refer to the "How do I use Psy-ARP?" section of the root README.md or visit this link:

<https://github.com/Tori-Tech/PsyARP/blob/main/README.md>

To use this tool, you must first have a few key items:

1. The IP addresses of the two hosts you wish to attack.

2. An image file, a PDF file, and a .zip file.
3. A python 3 HTTP server.
4. Wireshark installed on your attacker's machine.

Obviously, obtaining the IP addresses is the hardest part and will be dealt with during the reconnaissance phase of penetration testing. However, for the sake of this demonstration, we will effectively skip that stage and jump right into the spoofing.

Do note that before you run the script, you must make a folder for your HTTP server and place the image, PDF, and .zip files into that folder. Once you have done so, start your HTTP server. Afterwards, you may start the main Psy-ARP script and follow the on-screen prompts.

If everything is successful, the script will begin outputting long lines of text. You may now open a separate terminal and open Wireshark. Once you enable packet capturing, you should see a great deal of network traffic flowing between the two hosts. You may now inspect the traffic and see what interesting things you can find. Below, you will find a few documented instances of file redirection attacks performed with this tool.

Network Key:

Here is a reference for the IP addresses you will see in the attached screenshots throughout this writeup.

Kali Linux (attacker machine): 10.0.2.15

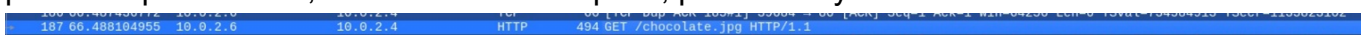
Ubuntu Linux (web server): 10.0.2.4

Linux Mint (victim machine): 10.0.2.6

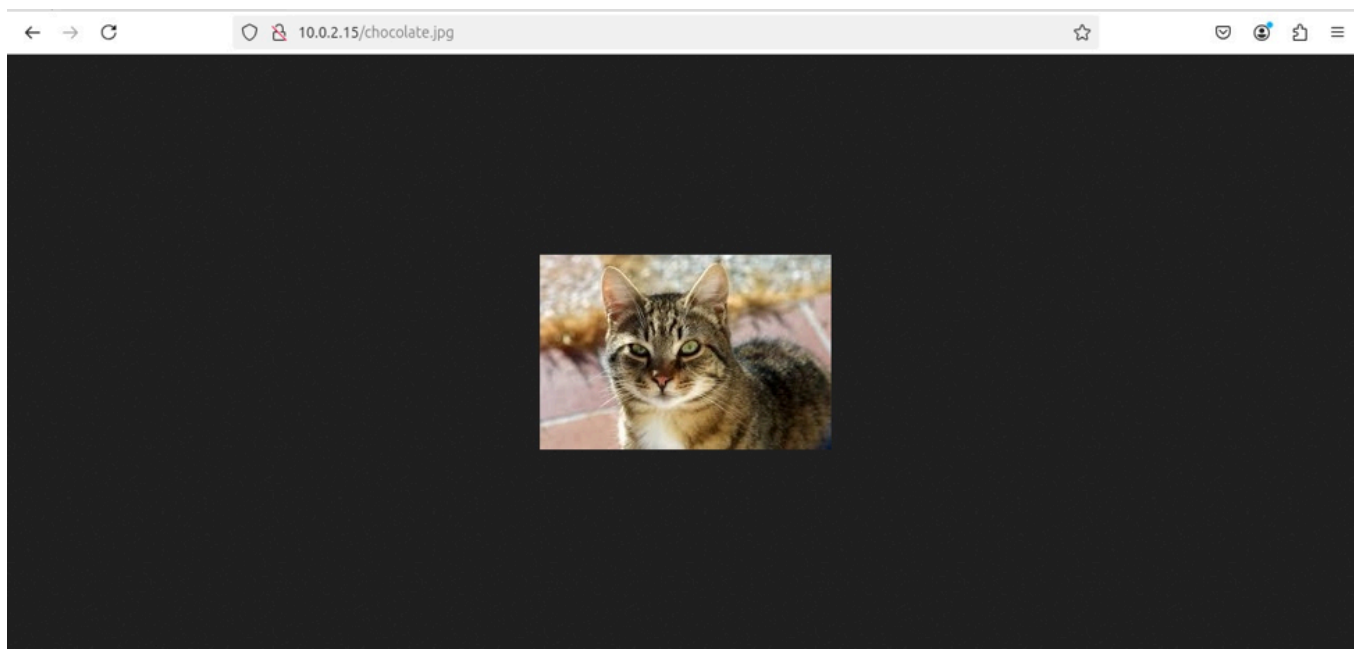
File Redirection Attacks:

To successfully complete an image redirection attack, one of the hosts must first request an image. Doing so is simple: There is a .jpeg file titled "chocolate.jpeg", that is stored in the "htdocs" folder on the Ubuntu machine, which is running Apache webserver. The Linux Mint machine makes a simple request using through the web browser, asking for this image like this:

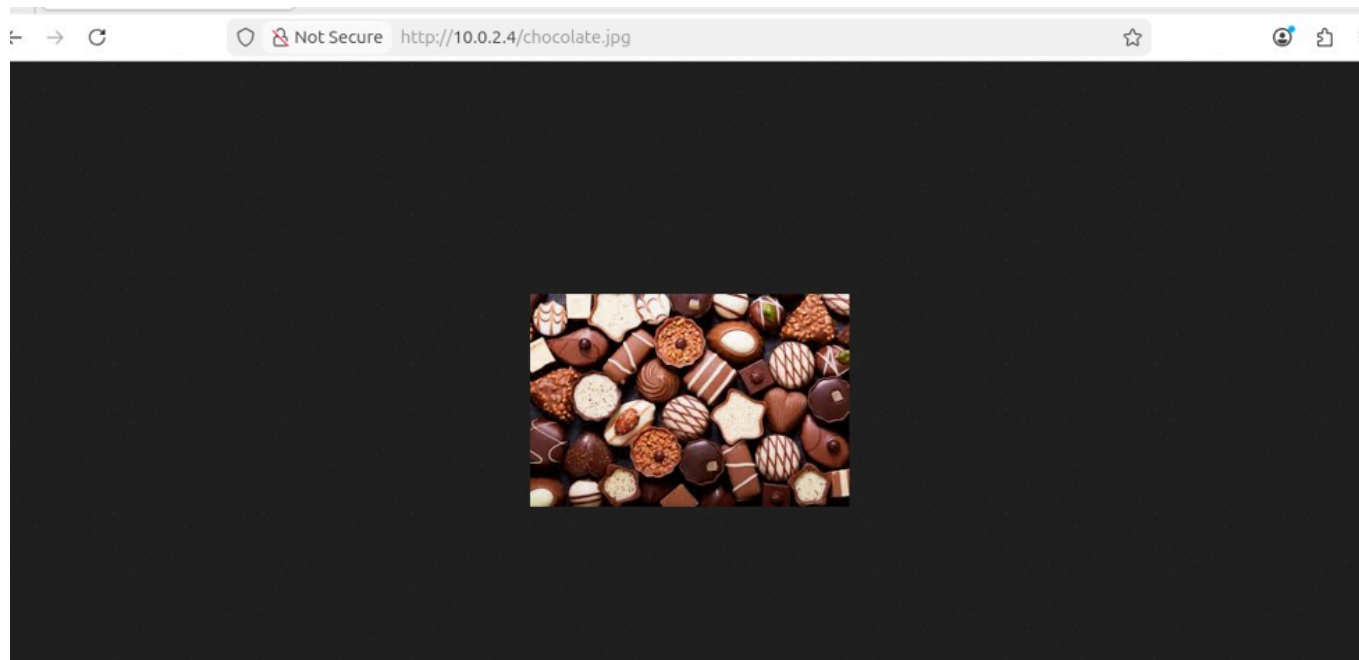
`http://10.0.2.6/chocolate.jpg` The Linux Mint machine could also request the image by using curl, but either way produces a .jpg file request. With Psy-ARP running and Wireshark's packet capture active, we can see this request, plain as day:



The script will automatically intercept and redirect that image request, replacing it with the .jpeg file located on your Python HTTP server. The machine that requested the image will get a response that looks like this:



When they should have received this:

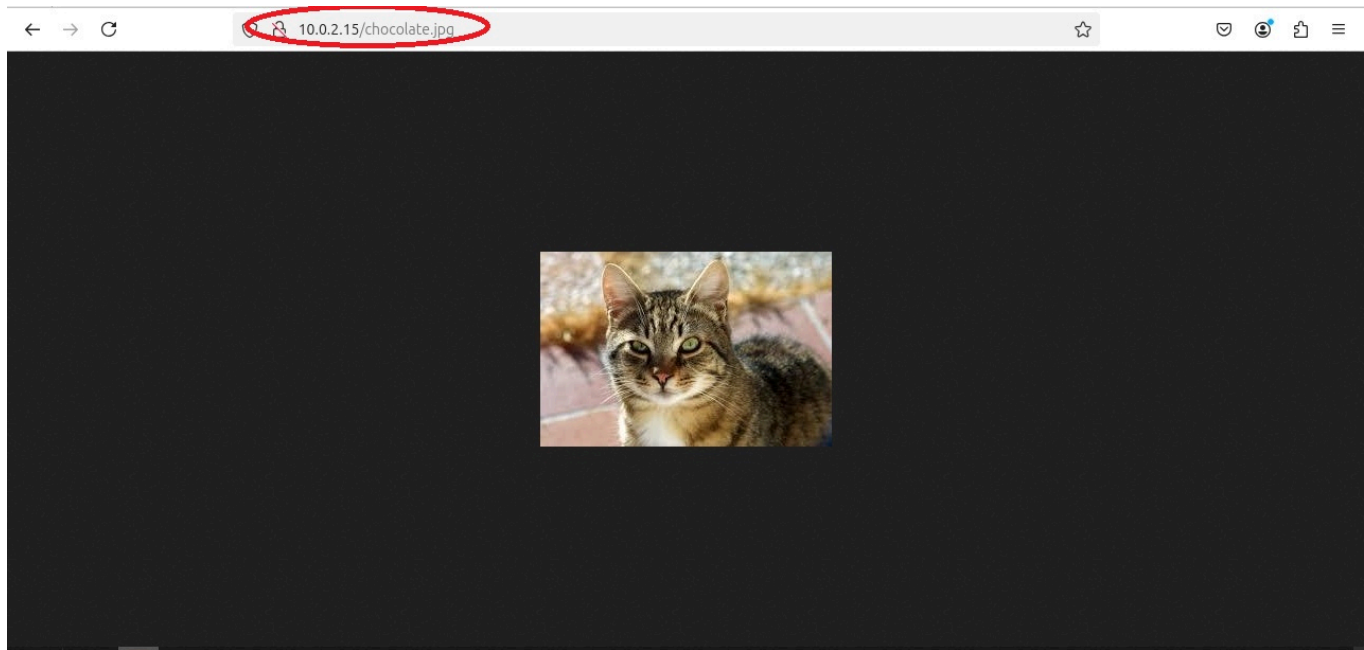


It is very clear that the file was not “chocolate.jpg”, which was what the victim requested. This process can be applied to intercept PDF and .zip files. While PDF files may easily be viewed in the browser, .zip files are more dangerous, as their contents are usually not known to a user until *after* they have been unzipped. This could allow an attacker to hide malicious files within a .zip file, exploiting an average user’s ignorance.

Identification, Defensive Measures, & Remediation:

As established earlier, Psy-ARP uses a simple Python HTTP server to host the attacker’s files so Psy-ARP can redirect requests to that server. This means that the attacker’s IP address will be prevalent on network logs. The network itself, in fact, can detect that something is amiss due to repeated packet output. This can be seen here.

It is also very obvious after redirection that the attacker's IP address appears in the victim's browser search bar, as shown here.



This means it would be relatively easy for an analyst to identify the source of the interference and block the attacker's IP address or take more drastic measures, if necessary. It would, of course, be impossible for the attacker to even perform MITM attacks if access to the network is kept under strict security, so ensuring accidental access points are removed and that network access is protected and authenticated properly is the most effective method of defending against MITM attacks.